UAE HACKATHON 2026 · CHALLENGE #27 · 2-MINUTE Q&A PREPARATION

Judge Q&A وكالة

Short, defensible answers. Answer in one or two sentences, then stop. Offer the evidence file if they want more.

Technology and security

1. Isn't this just IAM or an API gateway? No. IAM answers "may this role call this API?". WAKALA answers "may *this agent*, acting for *this citizen's case*, under *this mandate and delegation chain*, do *this exact action* now?". On the same 720 attacks, a role-only check let 624 through and WAKALA let none through. That baseline is deliberately weak, and we say so.

2. How does it work across different agent platforms? The control sits at the protected service, not inside the model. Any platform's agent, or a server-side adapter acting for it, signs a request. The gateway checks it against the mandate. The prototype's adapter already signs on the agent's behalf, and unknown or invalid tools never reach the gateway.

3. What stops an agent from giving itself more authority? Agents cannot issue mandates. Child mandates are issued and signed by WAKALA after an authorized commission, and they can only narrow the parent. A self-signed or widened child is rejected. This is covered by the security-invariant tests (28 parametrised attack variants) and the delegation attack suite.

4. What about prompt injection? Two layers. Document Shield quarantines suspicious PDFs, such as hidden white text, so the agent never sees them. More importantly, even a fully manipulated agent cannot exceed its mandate: an injected "pay AED 50,000 to an external account" is denied by amount and recipient limits. We have **not** tested a live model's behaviour, and we do not claim to have.

5. Did you use a real LLM? Not in the verified demo. It uses a clearly labelled deterministic offline planner. Model tool calling is built and tested with a recording fake client, and a real-model test exists but was not run because no model credential was configured. We chose honesty over a faked result.

6. Does it slow services down? In the prototype, the median full gateway authorization was about 19 ms in memory and about 55 ms with persisted SQLite, on one laptop in a single process. That is a prototype measurement, not a production SLA. The pilot re-measures it against an agreed latency budget.

7. How do you detect bad behaviour, and is it AI? Behaviour Watch uses deterministic, rule-based signals: cross-citizen access, delegation escalation, action after revocation, request rates and more. It escalates through a ladder from Observe to Revoke. It is not AI threat prediction, and the gateway decides independently of it.

8. What happens to the citizen when an agent is stopped? Only the affected mandate and case are paused. An officer reassigns the task to a standby agent and the case completes "recovered after a security review". Unrelated cases continue. In repeated runs, recovery was 20/20 five times and 50/50 in a long run.

9. Your Phase 5 recovery was 2/20. Why should we trust the fix? We found the root cause: agent-wide counters attached incidents to the wrong cases. We fixed it narrowly, kept the original result visible, and re-ran it. The original policy still reproduces 2/20, and the fixed policy gives 20/20 every time. Every attack was still denied.

10. Can the audit log be tampered with? It is hash-chained, so editing or deleting a record breaks verification. Its known limit is that truncating the tail, or a consistent rewrite by the database owner, is not detected without external anchoring, which is in the pilot plan.

11. Is it production-ready? No. It is a single process with SQLite and development keys, and it has no government integration. The 90-day pilot replaces these with the entity's key management, identity provider and database, on one service.

Data

12. Which open government data did you use? None feeds the benchmark, and we state that plainly. WAKALA governs agent *actions*, so it can prove its controls on synthetic records without touching personal data, as the playbook asks. In a pilot, the entity's test data replaces the synthetic records.

13. Are your numbers real? They are real executions on synthetic data, with a fixed seed of 1,200 labelled requests. Every figure traces to `evidence/` files. They are not government statistics and not production performance.

Business and feasibility

14. Who buys this? Entities deploying AI agents (service owners and CISOs), central digital-government and cyber authorities that need common assurance, and platform suppliers that must show equivalent protection.

15. How do you make money? Proposed: an annual entity licence tiered by protected services and agents, a fixed-scope pilot fee, a supplier conformance kit, and integration services. Prices are not set yet. We will validate them in the pilot, and we claim no market figures.

16. Why wouldn't a big vendor just build this? A vendor's own controls protect its own platform. Government needs one independent control that applies the same mandate rules to every vendor. Platform neutrality is the point.

17. What exactly happens in 90 days? Days 1–30: Shadow Mode on one low-risk service, which observes only. Days 31–60: enforce one case type with officers in the loop, plus an independent security test. Days 61–90: recovery drills and a go/no-go decision on agreed KPIs.

18. What do you need from us? One entity and service owner as pilot partner, a sandbox with test data and identity integration, and a joint security review.

19. What is the biggest risk? False denials disrupting a real service. That is why the pilot starts in Shadow Mode. On our synthetic workload Shadow Mode predicted enforcement 11/11, and it found one policy conflict (mandate expiry) before anything was blocked.

20. Licensing issues? Document Shield uses PyMuPDF, which is AGPL. Before commercial use it needs a commercial licence or a replacement. This is listed in our cost structure.
